

Family Care — Android Device Agent API Handbook

Audience: Android / Kotlin Device Owner (DPC) engineer and Cursor agents working on the parent-phone app.

Source of truth: Next.js backend contracts in this repository (src/types/contracts/*, src/app/api/device/*, src/app/api/enrollments/redeem).

Base URL (local): http://localhost:3000

OpenAPI (human UI): http://localhost:3000/swagger

OpenAPI JSON: http://localhost:3000/api/openapi

API است و مستقیماً Next.js/PWA این سند مخصوص اپ اندروید روی گوشی والد است. اپ مراقب صحبت Device Agent APIs و Command از طریق backend اندروید را صدا نمی‌زند. اندروید فقط با می‌کند.

1. Architecture (must follow)

Caregiver PWA

- Next.js API (auth + permissions)
- Command row (PENDING)
- Android Agent polls /api/device/commands/pending
- Android executes via official Android APIs
- Android reports progress + result
- Next.js updates DB + realtime events
- Caregiver PWA

Rules:

1. Next.js never calls Android Contacts/Settings APIs directly.
2. Android never talks to the caregiver UI; only to Next.js.
3. If an operation is not officially supported → return UNSUPPORTED (do not hack with Accessibility/root/UI automation).
4. Device identity is an **app-generated random id** (deviceIdentifier). Never use IMEI/MAC/serial as identity.
5. deviceCredential is a secret. Store in EncryptedSharedPreferences / Keystore. Never log it.

2. Error format (all APIs)

```
{
  "error": {
    "code": "DEVICE_UNAUTHENTICATED",
    "message": "Device credentials are required."
  }
}
```

Common codes for device agent:

Code	HTTP	Meaning
DEVICE_UNAUTHENTICATED	401	Missing/invalid Bearer credential
ENROLLMENT_TOKEN_INVALID	400	QR token invalid/expired/used
DEVICE_IDENTIFIER_IN_USE	409	deviceIdentifier already enrolled
COMMAND_NOT_FOUND	404	Unknown command for this device
COMMAND_ALREADY_FINISHED	409	Command already terminal
COMMAND_NOT_CANCELLABLE	409	Cannot cancel while EXECUTING
GEOFENCE_NOT_FOUND	404	Geofence missing/disabled
VALIDATION_ERROR	400	Invalid/schema invalid
INVALID_JSON	400	Body not JSON

3. Authentication

3.1 Enrollment (no auth yet)

POST /api/enrollments/redeem has **no** Authorization header.

3.2 After enrollment (all device agent APIs)

```
Authorization: Bearer <deviceCredential>
Content-Type: application/json
```

Notes:

- deviceCredential is returned **once** in enrollment response. Persist immediately.
 - Credential length must be ≥ 20 characters.
 - Backend stores only a hash; plaintext cannot be recovered.
 - Every authenticated device call also marks the device ONLINE and updates lastSeenAt.
-

4. Enrollment

4.1 QR payload (scanned by Android)

Caregiver PWA shows a QR encoding JSON:

```
{
  "v": 1,
  "token": "<one-time-enrollment-token>"
}
```

- v must be 1.
- token is short-lived and single-use (≈ 10 minutes on server).

4.2 Redeem enrollment

POST /api/enrollments/redeem

Request payload

```
{
  "token": "string min20 max200",
  "deviceIdentifier": "string min8 max200 (app-generated UUID recommended)",
  "name": "string min1 max80",
  "platform": "ANDROID",
  "manufacturer": "optional string",
  "model": "optional string",
  "androidVersion": "optional string e.g. 14",
  "androidSdk": 34,
  "appVersion": "optional string e.g. 1.0.0"
}
```

platform is **required** and must be exactly "ANDROID".

Success response 201

```
{
  "device": {
```

```
{
  "id": "uuid",
  "familyId": "uuid",
  "name": "مادر",
  "platform": "ANDROID",
  "status": "PENDING",
  "deviceCredential": "<SECRET – store securely, never log>"
}
```

Android responsibilities after enroll

1. Persist device.id, familyId, deviceCredential, deviceId.
2. Start command polling loop.
3. Report capabilities eventually (future); for now server may seed demo capabilities.

5. Command lifecycle (critical)

Statuses:

```
PENDING → SENT → RECEIVED → EXECUTING → SUCCESS | FAILED | UNSUPPORTED
                        ↘ EXPIRED | CANCELLED (terminal)
```

Device-side expected flow

1. GET /api/device/commands/pending
 - Server returns up to 20 commands currently PENDING.
 - Server **atomically marks them SENT** when returned.
2. Optionally PATCH /api/device/commands/{commandId} with { "status": "RECEIVED" }.
3. When execution starts: PATCH with { "status": "EXECUTING" }.
4. When finished: POST /api/device/commands/{commandId} with result (SUCCESS / FAILED / UNSUPPORTED).

Rules:

- Do not execute the same non-idempotent command twice.
 - If command expired on server → it will not appear in pending (or becomes EXPIRED).
 - While EXECUTING, caregiver cancel is rejected.
 - Prefer reporting UNSUPPORTED over crashing or faking success.
-

6. Device Agent APIs

6.1 Pull pending commands

GET /api/device/commands/pending

Headers

Authorization: Bearer <deviceCredential>

Success 200

```
{
  "commands": [
    {
      "commandId": "uuid",
      "id": "uuid",
      "familyId": "uuid",
      "deviceId": "uuid",
      "createdBy": "uuid",
      "type": "CREATE_CONTACT",
      "payload": { "displayName": "دكتور", "phoneNumber": "+9821..." },
      "status": "SENT",
      "resultData": null,
      "errorCode": null,
      "errorMessage": null,
      "createdAt": "2026-10-04T06:13:44.217Z",
      "expiresAt": "2026-10-05T06:13:44.215Z",
      "sentAt": "2026-10-04T06:14:00.000Z",
      "receivedAt": null,
      "startedAt": null,
      "completedAt": null
    }
  ]
}
```

Notes:

- `commandId` and `id` are the same UUID.
 - Empty list is valid: { "commands": [] }.
 - Poll periodically (e.g. every 5–15s) and also after reconnect / FCM wake if available later.
-

6.2 Update command progress

PATCH /api/device/commands/{commandId}

Request payload

```
{ "status": "RECEIVED" }
```

or

```
{ "status": "EXECUTING" }
```

Only RECEIVED and EXECUTING are allowed here.

Success 200

```
{
  "command": {
    "commandId": "uuid",
    "id": "uuid",
    "status": "EXECUTING",
    "receivedAt": "...",
    "startedAt": "...",
    "...": "same CommandView fields as pending"
  }
}
```

6.3 Submit command result

POST /api/device/commands/{commandId}

Success result payload

```
{
  "status": "SUCCESS",
  "data": { "...type-specific fields..." },
  "error": null
}
```

Failure / unsupported payload

```
{
  "status": "FAILED",
  "data": null,
  "error": {
    "code": "CONTACTS_PERMISSION_DENIED",
    "message": "WRITE_CONTACTS permission missing."
  }
}
```

```
{
  "status": "UNSUPPORTED",
  "data": null,
  "error": {
    "code": "SYSTEM_APP",
    "message": "Protected application."
  }
}
```

Success response 200

```
{
  "command": {
    "commandId": "uuid",
    "status": "SUCCESS",
    "resultData": { "...echoed/stored data..." },
    "errorCode": null,
    "errorMessage": null,
    "completedAt": "ISO-8601"
  }
}
```

6.4 Report location

POST /api/device/location

Use for last-known location updates (not continuous tracking). Prefer official location APIs + geofencing APIs.

Request payload

```
{
  "latitude": 35.6892,
  "longitude": 51.3890,
  "recordedAt": "2026-10-04T06:20:00.000Z",
}
```

```
"locationPermission": "GRANTED",
"locationServiceEnabled": true
}
```

Field	Required	Notes
latitude	yes	-90..90
longitude	yes	-180..180
recordedAt	no	ISO datetime; server uses now if omitted
locationPermission	no	UNKNOWN PROMPT GRANTED DENIED
locationServiceEnabled	no	boolean

Success 200

```
{ "ok": true }
```

6.5 Report geofence ENTER/EXIT

POST /api/device/geofence-events

Request payload

```
{
  "geofenceId": "uuid",
  "type": "ENTERED",
  "occurredAt": "2026-10-04T06:25:00.000Z"
}
```

type: ENTERED | EXITED

occurredAt optional ISO datetime.

Response

Accepted new event (201):

```
{
  "accepted": true,
  "notificationId": "uuid"
}
```

Deduped within server window (200):

```
{
  "accepted": false,
  "notificationId": null
}
```

Server dedupes identical geofence events for ~15 minutes.

7. Command catalog (payload in → result data out)

Use these exact type strings and payload shapes. Result data must match the SUCCESS shape for that type.

7.1 GET_DEVICE_INFO

Inbound payload: {}

SUCCESS data:

```
{
  "manufacturer": "Samsung",
  "model": "Galaxy A54",
  "androidVersion": "14",
  "androidSdk": 34,
  "appVersion": "1.0.0"
}
```

Nullable strings allowed for manufacturer/model/versions if unknown (null).

7.2 GET_BATTERY

Inbound payload: {}

SUCCESS data:

```
{
  "levelPercent": 80,
  "charging": false
}
```

7.3 GET_STORAGE

Inbound payload: {}

SUCCESS data:

```
{
  "totalBytes": 128000000000,
  "availableBytes": 42000000000
}
```

Use raw byte numbers (not strings).

7.4 CREATE_CONTACT

Inbound payload:

```
{
  "displayName": "دکتر نمونه",
  "phoneNumber": "+982100000000"
}
```

SUCCESS data (required):

```
{
  "contactId": "android-or-app-stable-id"
}
```

contactId is required by backend to persist the contact. Generate a stable id if Android does not provide one you can reuse.

7.5 UPDATE_CONTACT

Inbound payload:

```
{
  "contactId": "contact-xyz",
  "displayName": "optional new name",
  "phoneNumber": "optional new phone"
}
```

SUCCESS data:

```
{ "contactId": "contact-xyz" }
```

7.6 DELETE_CONTACT

Inbound payload:

```
{ "contactId": "contact-xyz" }
```

SUCCESS data:

```
{ "contactId": "contact-xyz" }
```

7.7 GET_INSTALLED_APPS

Inbound payload: {}

SUCCESS data:

```
{
  "apps": [
    { "packageName": "org.telegram.messenger", "label": "Telegram" }
  ]
}
```

7.8 INSTALL_APP

Inbound payload:

```
{ "packageName": "com.spotify.music" }
```

SUCCESS data:

```
{ "packageName": "com.spotify.music" }
```

If silent install is not possible → UNSUPPORTED (do not fake). Capability flag `silentInstall` exists in contracts; currently often false.

7.9 UNINSTALL_APP

Inbound payload:

```
{ "packageName": "com.example.app" }
```

SUCCESS data:

```
{ "packageName": "com.example.app" }
```

If protected/system app → prefer UNSUPPORTED with a clear error code.

7.10 ENABLE_APP / DISABLE_APP

Inbound payload:

```
{ "packageName": "com.example.app" }
```

SUCCESS data:

```
{ "packageName": "com.example.app" }
```

7.11 GET_LOCATION

Inbound payload: {}

SUCCESS data:

```
{  
  "latitude": 35.6892,  
  "longitude": 51.3890,  
  "recordedAt": "2026-10-04T06:20:00.000Z"  
}
```

Also keep posting /api/device/location for dashboard last-known location.

7.12 CREATE_GEOFENCE

Inbound payload:

```
{
  "geofenceId": "uuid-from-server",
  "name": "خانه",
  "latitude": 35.6892,
  "longitude": 51.3890,
  "radiusMeters": 200
}
```

Constraints used by caregiver API: radius 50..50000 meters.

SUCCESS data:

```
{ "geofenceId": "uuid-from-server" }
```

Android must:

1. Register the geofence with official Android Geofencing API using `payload.geofenceId` as the request id / stable key.
2. Echo the same geofenceId in SUCCESS data.
3. Use that same UUID in `/api/device/geofence-events`.

7.13 UPDATE_GEOFENCE

Inbound payload:

```
{
  "geofenceId": "uuid",
  "name": "خانه",
  "latitude": 35.69,
  "longitude": 51.39,
  "radiusMeters": 250,
  "enabled": true
}
```

All fields except geofenceId optional.

SUCCESS data:

```
{ "geofenceId": "uuid" }
```

7.14 DELETE_GEOFENCE

Inbound payload:

```
{ "geofenceId": "uuid" }
```

SUCCESS data:

```
{ "geofenceId": "uuid" }
```

7.15 GET_SETTINGS

Inbound payload: {}

SUCCESS data:

```
{
  "settings": {
    "device_name": "مادر",
    "screen_timeout_seconds": 60,
    "developer_options": false,
    "wifi_enabled": true,
    "mobile_data_enabled": true,
    "brightness": 70,
    "auto_brightness": true,
    "font_scale": 1.15,
    "ring_volume": 6,
    "media_volume": 8,
    "do_not_disturb": false,
    "screen_lock_enabled": true,
    "install_unknown_apps": false,
    "auto_update_apps": true
  }
}
```

Values must be string | number | boolean only.

Known keys (backend catalog):

key	type	writable
device_name	string	yes
screen_timeout_seconds	number	yes
developer_options	boolean	no
wifi_enabled	boolean	yes

key	type	writable
mobile_data_enabled	boolean	yes
airplane_mode	boolean	no
brightness	number	yes
auto_brightness	boolean	yes
font_scale	number	yes
ring_volume	number	yes
media_volume	number	yes
do_not_disturb	boolean	yes
screen_lock_enabled	boolean	yes
unknown_sources	boolean	no
install_unknown_apps	boolean	yes
auto_update_apps	boolean	yes

Only report keys you can read via official APIs. Omit unsupported keys rather than inventing values.

7.16 SET_SETTING

Inbound payload:

```
{
  "key": "brightness",
  "value": 70
}
```

SUCCESS data:

```
{ "key": "brightness" }
```

If key/value cannot be applied officially → UNSUPPORTED or FAILED with clear error.

8. DeviceCapability contract

Android should eventually report a capability map matching:

```
{
  "GET_DEVICE_INFO": true,
  "GET_BATTERY": true,
  "GET_STORAGE": true,
  "CREATE_CONTACT": true,
  "UPDATE_CONTACT": true,
  "DELETE_CONTACT": true,
  "GET_INSTALLED_APPS": true,
  "INSTALL_APP": false,
  "UNINSTALL_APP": false,
  "ENABLE_APP": false,
  "DISABLE_APP": false,
  "GET_LOCATION": true,
  "CREATE_GEOFENCE": true,
  "UPDATE_GEOFENCE": true,
  "DELETE_GEOFENCE": true,
  "GET_SETTINGS": true,
  "SET_SETTING": false,
  "silentInstall": false
}
```

PWA only exposes operations that are true. Do not claim true unless officially supported on the device/Android version/policy.

9. Minimal Kotlin agent loop (pseudo)

```
// 1) Scan QR → EnrollmentQrPayload(v=1, token)
// 2) POST /api/enrollments/redeem
// 3) Save deviceCredential

while (running) {
  val pending = GET("/api/device/commands/pending") // Bearer credential
  for (cmd in pending.commands) {
    PATCH("/api/device/commands/${cmd.id}", body = {"status":"RECEIVED"})
    PATCH("/api/device/commands/${cmd.id}", body = {"status":"EXECUTING"})
    val result = executeOfficially(cmd.type, cmd.payload)
    POST("/api/device/commands/${cmd.id}", body = result)
  }
  delay(pollInterval)
}
```

Geofence callbacks (Android Geofencing API):

```
POST("/api/device/geofence-events", {  
  "geofenceId": serverUuid,  
  "type": "ENTERED", // or EXITED  
  "occurredAt": isoNow  
})
```

10. Security checklist for Android Cursor agent

- ☐ No root / Accessibility automation / UI automation for management
- ☐ No undocumented/hidden Android APIs
- ☐ No logging of token, deviceCredential, passwords
- ☐ Use app-generated deviceId (UUID)
- ☐ Persist credential encrypted
- ☐ Capability-driven feature flags
- ☐ Return UNSUPPORTED when OS/policy blocks the action
- ☐ Offline-first: commands wait in PENDING until device polls
- ☐ TLS in production; local HTTP only for emulator/dev

11. Local verification (with running Next.js)

1. Start backend: `pnpm dev` (and Postgres via `docker compose up -d`).
2. Login caregiver, create enrollment QR from family page.
3. Redeem with Android emulator/agent against `http://10.0.2.2:3000` (emulator → host) or LAN IP.
4. Create a contact command from PWA.
5. Confirm Android pending pull sees SENT, then result becomes SUCCESS.
6. Confirm contact appears in PWA contacts page.

Demo caregiver account (local seed):

- email: `owner@example.com`
- password: `demo-password`

Demo device credential used by backend verify scripts (seeded):

`demo-device-credential-token-sprint3-verify`

(only for local verification fixtures; production devices use enrollment response credential).

12. Cursor prompt starter (paste to Android project)

You are implementing the Family Care Android Device Owner / DPC agent.

Read docs/android-agent-api-handbook.md as the API contract source of truth.

Implement:

- 1) QR enrollment redeem against POST /api/enrollments/redeem
- 2) Secure storage of deviceCredential
- 3) Polling GET /api/device/commands/pending with Bearer auth
- 4) Progress PATCH RECEIVED/EXECUTING
- 5) Result POST SUCCESS/FAILED/UNSUPPORTED with type-specific data shapes
- 6) Location POST /api/device/location
- 7) Geofence events POST /api/device/geofence-events using official Android Geofencing API
- 8) Official Android APIs only; no Accessibility/root/UI automation
- 9) Capability-driven support; return UNSUPPORTED when blocked

Do not invent endpoints. Match payloads/responses exactly from the handbook.

13. Endpoint summary

Method	Path	Auth	Purpose
POST	/api/enrollments/redeem	none	Enroll device, get credential
GET	/api/device/commands/pending	Bearer	Pull + claim PENDING→SENT
PATCH	/api/device/commands/{commandId}	Bearer	Progress RECEIVED/EXECUTING
POST	/api/device/commands/{commandId}	Bearer	Final result
POST	/api/device/location	Bearer	Last-known location
POST	/api/device/geofence-events	Bearer	ENTERED/EXITED

Caregiver/PWA APIs are intentionally omitted here; Android agent should not use caregiver cookie session APIs.

Generated from the Next.js Family Care backend contracts for Android Device Owner integration.